

ROADMAP CYBERFLOW ACADEMY

Guida Dettagliata al Percorso Formativo in Ethical Hacking & Cybersecurity

Documento Analitico Modulo per Modulo • Metodologia Step-by-Step • Curriculum Tecnico Completo

Metodologia Formativa & Struttura del Percorso

Il programma di CyberFlow Academy si snoda attraverso **6 Step progressivi** concepiti per accompagnare lo studente dalla configurazione iniziale dell'ambiente di lavoro fino alla specializzazione avanzata e alla monetizzazione tramite Bug Bounty. Ogni modulo unisce concetti teorici fondamentali a laboratori pratici guidati.

STEP 1

Accoglienza, Mindset & Setup dell'Ambiente

Fase di orientamento, etica professionale e predisposizione del laboratorio di attacco controllato.

1.1 Benvenuto, Etica & Mindset dell'Hacker

- **Confini Legali & Responsabilità:** Analisi delle leggi sul cybercrime, autorizzazioni scritte, contratti di ingaggio (Scope) e codice deontologico dell'Ethical Hacker.
- **Mindset da Problem Solver:** Sviluppare la mentalità analitica, gestione della frustrazione durante la ricerca di vulnerabilità ed "escape dal tutorial hell".

1.2 Setup del Laboratorio Virtuale

- **Virtualizzazione Avanzata:** Installazione e configurazione ottimizzata di Hypervisor (Oracle VirtualBox / VMware Workstation).
- **Installazione Kali Linux & Parrot OS:** Configurazione delle VM d'attacco, allocazione risorse, installazione di Guest Additions e personalizzazione della shell Bash/Zsh.
- **Isolamento di Rete:** Configurazione delle schede di rete virtuali (NAT, Host-Only, Internal Network) per garantire test in totale sicurezza senza esporre la rete domestica.

1.3 Integrazione Community & Risorse

- **Server Discord Privato:** Canali di supporto, suddivisione delle stanze di studio e networking strategico con altri studenti.
- **Cheat Sheet & Documentazione:** Accesso ai ricettari pronti all'uso per comandi rapidi, prontuari di sintassi e risorse di supporto.

Kali Linux

VirtualBox

VMware

OPSEC Base

Discord Community

STEP 2

Ethical Hacking Core (Le Basi dell'Attacco)

Apprendimento delle tecniche fondamentali di attacco: ricognizione, scansione e penetrazione dei sistemi.

2.1 Fondamenti di Linux per Hacker

- **Padronanza della Shell Bash:** Navigazione nel file system, filtri di testo avanzati (grep, sed, awk, cut, sort, uniq), reindirizzamento degli standard input/output.
- **Permessi & Processi:** Gestione utenti/gruppi, CHMOD, CHOWN, bit SUID/SGID, gestione daemon di sistema e controllo dei processi con systemctl e ps.

2.2 Reconnaissance & Information Gathering

- **OSINT Passiva:** Raccolta dati da registranti domini (WHOIS, RDAP), interrogazione server DNS (dig, nslookup, host) ed estrazione e-mail/subdomain con theHarvester e Amass.
- **Ricerca su Motori Specializzati:** Query avanzate su Shodan, Censys e Google Hacking Database (Google Dorks) per scoprire servizi esposti.

2.3 Scanning & Vulnerability Assessment

- **Nmap Mastery:** Scansioni TCP SYN (-sS), Connect (-sT), UDP (-sU), Banner Grabbing, Scripting Engine (NSE) e strategie di elusione dei Firewall/IDS.
- **Alternative Veloci & Vulnerability Scanning:** Uso di Rustscan e Masscan per scansioni ad alta velocità e valutazione delle falle note tramite Nessus / OpenVAS.

2.4 Exploitation & Metasploit Framework

- **Architettura di Metasploit:** Moduli Exploit, Payload, Auxiliary, Post ed Encoder; utilizzo di msfconsole e msfvenom per la creazione di trojan/stager.
- **Reverse vs Bind Shell:** Differenze concettuali, gestione del listener Netcat/Metasploit, stabilizzazione della shell (python pty spawn) e Port Forwarding base.

2.5 Advanced Exploitation & Evasione Base

- **Meterpreter Deep Dive:** Privileges escalation preliminare, dump delle hash delle password (mimikatz, hashdump), pivoting tra sotto-reti interne.
- **Introduzione all'AV Evasion:** Offuscamento del codice payload, utilizzo di wrapper e tecniche base per bypassare Windows Defender.

Linux Bash

Nmap

Metasploit

Shodan

Netcat

Privilege Escalation

STEP 3

Core Foundations (Networking & Programmazione)

Costruzione delle fondamenta informatiche imprescindibili: architetture di rete e sviluppo di tool personalizzati.

3.1 Networking+ & Analisi del Traffico

- **Modelli OSI & TCP/IP:** Analisi dettagliata di tutti e 7 i livelli, incapsulamento dei pacchetti, intestazioni IP, TCP, UDP e ICMP.
- **Protocolli Fondamentali:** Funzionamento profondo di ARP, DNS, DHCP, HTTP/HTTPS, SSH, FTP, SMB e BGP; calcolo delle sotto-reti (Subnetting VLSM).
- **Packet Sniffing con Wireshark:** Cattura del traffico di rete, filtri di visualizzazione complessi, ricostruzione di stream TCP ed estrazione di credenziali in chiaro.
- **Attacchi di Rete:** Man-In-The-Middle (MITM), ARP Poisoning con Bettercap/Ettercap, Rogue DHCP e DNS Spoofing.

3.2 Python for Hackers (Sviluppo Tool Custom)

- **Basi del Linguaggio Python:** Strutture dati, gestione eccezioni, libreria standard e moduli orientati alla sicurezza.
- **Network Programming (Socket):** Scrittura da zero di un Port Scanner multi-threaded, client/server TCP e un listener custom per Reverse Shell.
- **Automazione & Web Scraping:** Utilizzo delle librerie requests e BeautifulSoup per realizzare script di Directory Bruteforcing e Banner Scraper.
- **Manipolazione Pacchetti con Scapy:** Creazione e invio di pacchetti di rete personalizzati, crafting di SYN Flood ed estrazione di dati dai file PCAP.

3.3 C & C++ for Hackers (Programmazione di Basso Livello)

- **Gestione della Memoria:** Allocazione dinamica (malloc/free), puntatori, stack, heap e organizzazione della memoria nei processi.
- **Windows API & Shellcoding:** Chiamate Win32 API per l'iniezione di codice in processi remoti (Process Injection, DLL Injection).
- **Concetti di Buffer Overflow:** Comprensione teorico-pratica di come i dati sovrascrivono il registro EIP/RIP per dirottare il flusso di esecuzione.

Wireshark

TCP/IP

Python

Socket

Scapy

C / C++

Win32 API

STEP 4

Security Mindset & OPSEC (Protezione e Anonimato)

Strategie avanzate per l'Operational Security, l'anonimato in rete e la messa in sicurezza dei sistemi.

4.1 Operational Security (OPSEC) & Threat Modeling

- **Threat Modeling:** Valutazione delle minacce, analisi delle proprie impronte digitali (digital footprint) e identificazione dei vettori di tracciamento.
- **Gestione delle Identità Separata:** Compartimentazione delle attività, utilizzo di Burner Accounts e gestione sicura delle chiavi di cifratura.

4.2 Anonimato & Privacy in Rete

- **La Rete Tor & Proxymchains:** Architettura dell'onion routing, configurazione di nodi di uscita e instradamento del traffico di attacco tramite Proxymchains.
- **VPN & Multi-Hop:** Selezione di provider VPN no-log, configurazione di VPN in cascata e prevenzione dei DNS/IPv6 Leak.
- **Sistemi Operativi Orientati alla Privacy:** Panoramica sull'uso di Tails OS (Live OS) e Whonix per la massima riservatezza.

4.3 System Hardening & Privacy Tools

- **Hardening del Browser:** Configurazione estrema di Mozilla Firefox (user.js, uBlock Origin, Privacy Badger, disattivazione WebRTC).
- **Messa in Sicurezza di Windows & Linux:** Script di automazione per disattivare la telemetria di Windows, configurazione di UFW/IPTables, chiusura delle porte inutilizzate e hardening di SSH (chiavi RSA/ED25519, disattivazione root login).

OPSEC

Tor Network

Proxymchains

Tails OS

Hardening

UFW

STEP 5

Web Hacking & Bug Bounty Path

Sicurezza delle applicazioni web, metodologia OWASP e tecniche di monetizzazione con i programmi Bug Bounty.

5.1 Fundamentals di Web Security & Burp Suite

- **Funzionamento di una Web App:** Architettura Client-Server, richieste/risposte HTTP, header di sicurezza, cookie di sessione, Same-Origin Policy (SOP) e CORS.
- **Burp Suite Pro/Community:** Intercettazione del traffico HTTP, uso del Repeater per modificare i pacchetti, Intruder per attacchi di forza bruta, e configurazione di estensioni custom.

5.2 OWASP Top 10 Vulnerabilities Deep Dive

- **SQL Injection (SQLi):** In-Band (Union-Based, Error-Based), Blind (Boolean-Based, Time-Based) e automazione completa tramite SQLMap.
- **Cross-Site Scripting (XSS):** Reflected XSS, Stored XSS e DOM-Based XSS; creazione di payload per il furto dei cookie di sessione e bypass dei filtri WAF.
- **Broken Access Control & IDOR:** Insecure Direct Object References, bypass dei controlli di autorizzazione e privilege escalation orizzontale/verticale nei pannelli web.
- **Altre Falle Cruciali:** Server-Side Request Forgery (SSRF), Cross-Site Request Forgery (CSRF), File Upload Insecure (esecuzione di Web Shell PHP) e Command Injection.

5.3 Metodologia Bug Bounty & Playbook da \$1,000

- **Piattaforme di Bug Bounty:** Come muoversi su HackerOne, Bugcrowd, Intigriti e YesWeHack; scelta del target ideale ed esame delle Scope Policy.
- **Ricognizione Web Automata:** Utilizzo di tool moderni come Sublist3r, Assetfinder, httpx, gau e ffuf per scovare endpoint nascosti prima della concorrenza.
- **Scrittura di Report Professionali:** Come documentare la vulnerabilità (Proof of Concept - PoC), attribuire il punteggio CVSS e comunicare efficacemente con i triage team per evitare la marcatura "Duplicate" o "Informational".

5.4 Laboratori Pratici & Web Labs

- **Esercitazioni Guidate:** Risoluzione di lab complessi su DVWA (Damn Vulnerable Web App), OWASP Juice Shop e PortSwigger Web Security Academy.

OWASP Top 10

Burp Suite

SQL Injection

XSS

IDOR

Bug Bounty

HackerOne

Specialization Tracks (Tracce di Specializzazione)

Moduli avanzati dedicati alle discipline verticali di alto livello nell'ambito cyber.

6.1 OSINT Avanzata (Open Source Intelligence)

- **SOCMINT & Person Investigation:** Tracciamento di profili sui social media, ricerca di footprint digitali e correlazione di dati con Maltego e SpiderFoot.
- **GEOINT & Metadata Analysis:** Geolocalizzazione di immagini tramite punti di riferimento, analisi dei dati EXIF dei file multimediali e tracciamento di risorse domini con GHUNT.

6.2 Reverse Engineering & Ingegneria Inversa

- **Analisi Binaria:** Disassemblaggio di eseguibili Windows (.exe, .dll) e Linux (ELF) mediante Ghidra e x64dbg / IDA Free.
- **Analisi Statica e Dinamica:** Comprensione del codice Assembly (x86/x64), ispezione dei registri CPU, impiego di breakpoint per scavalcare licenze o analizzare comportamenti sospetti.

6.3 Mobile Hacking (Android)

- **Decompilazione APK:** Estrazione del codice sorgente Java/Kotlin da file APK utilizzando Jadx e apktool.
- **Dynamic Instrumentation con Frida:** Iniezione di script durante l'esecuzione dell'app per effettuare il bypass del SSL Pinning e la manomissione delle funzioni interne.
- **Intercettazione Traffico Mobile:** Installazione dei certificati di CA di Burp Suite sui dispositivi o emulatori Android.

6.4 IoT Security & AI applicata all'Ethical Hacking

- **IoT Hacking Intro:** Estrazione di file system da dump di firmware (binwalk), analisi di servizi esposti nei dispositivi embedded e protocolli come MQTT.
- **Intelligenza Artificiale nel PenTesting:** Prompt Engineering specifico per la velocizzazione della scrittura di exploit, analisi automatica dei log ed esecuzione assistita di code audit.

OSINT Avanzata

Ghidra

Assembly x86

Android Hacking

Frida

IoT Security

AI Security